CUA-Daily · 第二期 · arXiv 2609.02154v1 (WiP) · 移动端认证安全 · 问题档 P3 / judgment

验证码交对了，人却不一定在场

口令式 MFA 默认：输密码、去邮箱或认证器取码、再把码填回去，这几步之间**要有一个人来搬运**。作者让一个移动 GUI agent 在同一部手机上把三步连起来做完，称之为 **factor collapse（因素坍塌）**：不是破解，而是每个因素都被合法地取到、交上去。

侧翼 · 执行者

移动 GUI agent
GPT-5 mini · MobileRun
只走普通 UI 操作

注入

认证链（自上而下）· 示意

L0 · 设备锁 / 生物识别
已解锁（前提，不攻破）

L1 · 知识因素
账号 + 密码
主凭证由威胁模型给定；agent 打开目标服务、填入并提交。

L2 · 二次验证挑战
识别并触发 MFA
判断是否出现额外认证，点「发送验证码」。

L3 · 持有因素 · 跨 App
切到另一个 App 取码

- **邮件 OTP**：打开邮箱，刷新收件箱，找到新邮件，读出验证码
- **认证器动态码**：打开认证器 App，读当前码（不碰其密钥）

单 agent 在这里掉链
没刷新收件箱、在杂乱收件箱里找错邮件、交了过期码

~~MFA 原设想：人把码抄回登录页~~
现在：worker 之间交接 →

以及在这里
提前结束、谎称已完成、重复操作，耗光 15 步

L4 · 提交
回到登录页，填码
恢复登录上下文，输入验证码，完成剩余确认步骤。

终点 · 服务端看到的
已验证
进入登录后状态；服务端只看到验证码正确

作者的双 worker 分工

Worker A
Login OTP Retriever
输入凭证 → 检测挑战 → 去邮箱/认证器取码。
取码失败可单独重试，不用重输密码。

只传：服务、账号、流程状态、验证码

Worker B
Completion Worker
填码、确认、判断是否登录成功；填错可单独重来。

读数板 · 作者实验

§ 3.2 · 图 2（成功率）· 图 3（耗时）

10/10
个服务被 agent 走完整条认证链
双 worker 流水线 · 每个结果人工核查

基础单 agent **3/10**
只给登录目标；平均耗时 >200 秒

详细指令单 agent **6/10**
按平台写好步骤；三者中最快

双 worker 流水线 **10/10**
比详细指令版略慢，但全部完成（图 3 未给精确秒数）

同条件

- **10 个**商业网站 / App，覆盖多个服务类别
- 每个账号用**邮件 OTP**或**认证器动态码**之一
- 三种配置**同一预算：15 个动作**
- 成功 = 到达该服务的登录后状态；超预算或提前终止记失败
- 每个结果**人工核查**，并记录端到端耗时

读数时注意

- 服务名单未公开；没有短信验证码、没有生物识别因素
- 没写每个服务跑几次、有无重复，成功率无方差
- 只用一个模型；作者称为 WiP 初步结果

作者对 3→10 的解释

- 填表和取码分给两个 worker，减少来回切换上下文，收件箱里无关邮件的干扰也被隔开；代价是协调让耗时略增。

威胁模型边界 · 这是可行性演示，不是破解 MFA

- 假设已有：设备已解锁；agent 有 GUI 控制权限；持有用户主凭证；邮箱或认证器已在本机配置。
- 不假设：系统被攻破、拿到认证器密钥、绕过锁屏。
- 现实场景：有权限的 agent 被攻陷、被误导，或做了超出用户授权的事。测试账号均为授权账号。

作者附带的防御 pilot（不作为入选依据）

填码窗口内录加速度计 + 陀螺仪，分辨人手操作和 agent 操作：桌面 **98.4%**、手持 **92.6%**。只有 **4 名参与者、116 个会话**，按会话五折交叉验证，没有跨用户 / 跨设备留出，也没测针对传感器的适应性攻击。

MFA ≠ 人在场

当密码、取码、填码都能在同一部手机里由 agent 完成，「验证码提交正确」只说明**能操作这部手机的某个执行者**拿齐了因素，不再能证明是用户本人在操作。

阅读判断：基于作者 10/10 结果与威胁模型；作者自己的结论是需要「人在场」的补充证据（§ 4）。

来源：Characterizing and Defending Against Mobile-Agent-Driven MFA Automation（WiP），arXiv 2609.02154v1，2026-09-02。数字取自 § 3.2–§ 3.3 正文与图 2/3；认证链、图标、锁的破口均为自绘示意，层次按论文流程（§ 2.1 图 1）整理，不是论文原图。初筛：run gui-pc11-20261022-01 · L2 batches/l48.jsonl。